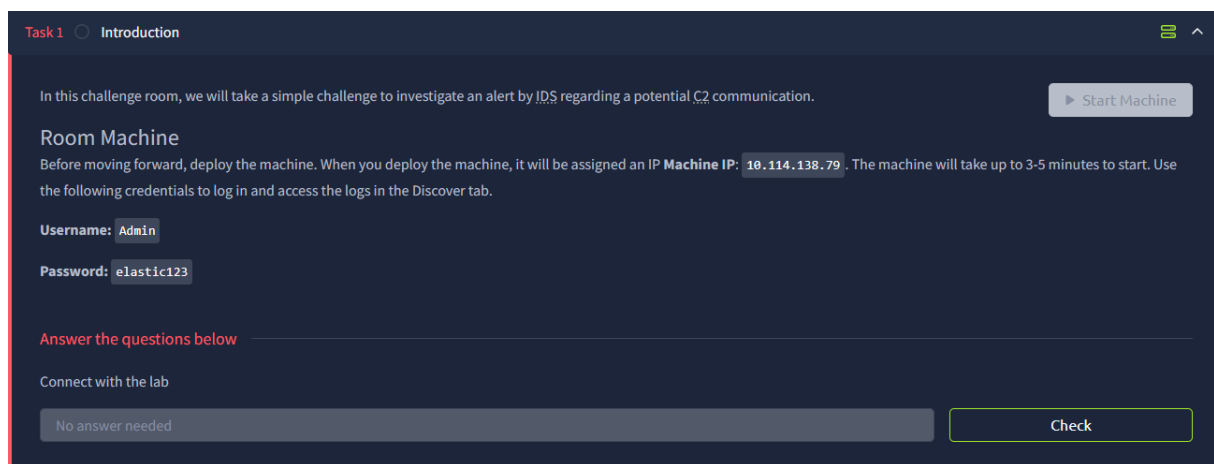
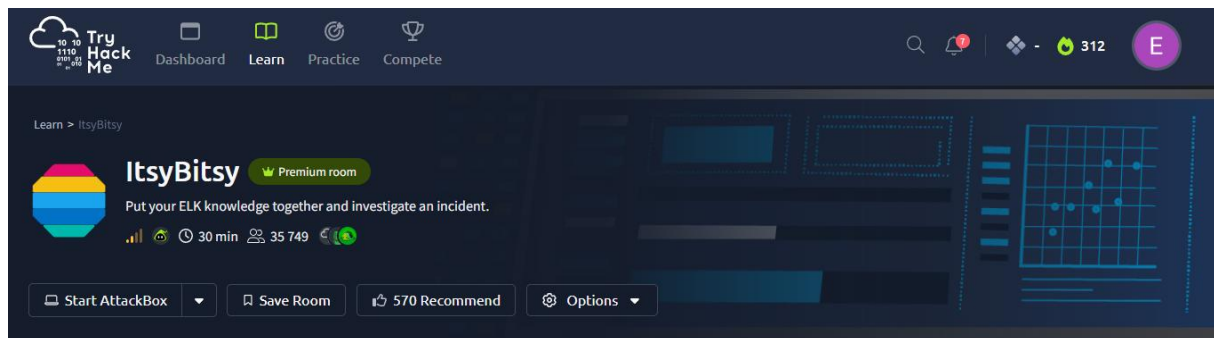


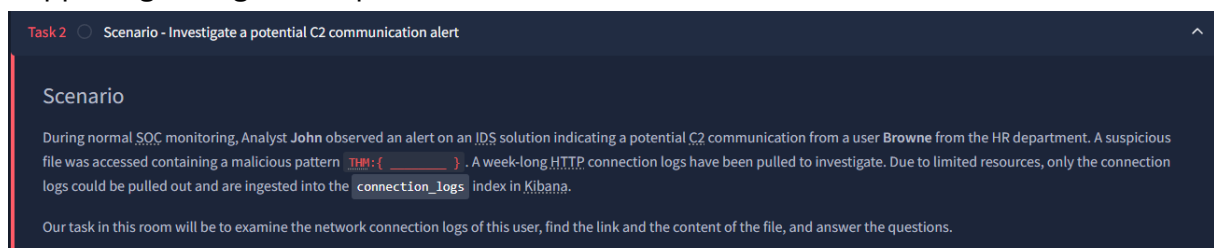
Introduction



Hello everyone, the goal for this challenge will be to investigate potentially malicious C2 communication happening in our organization based on the alerts by our IDS (Intrusion detection system). Alerts are saved in Elastic Stack and thanks to Kibana graphical interface we can analyze them.

Incident

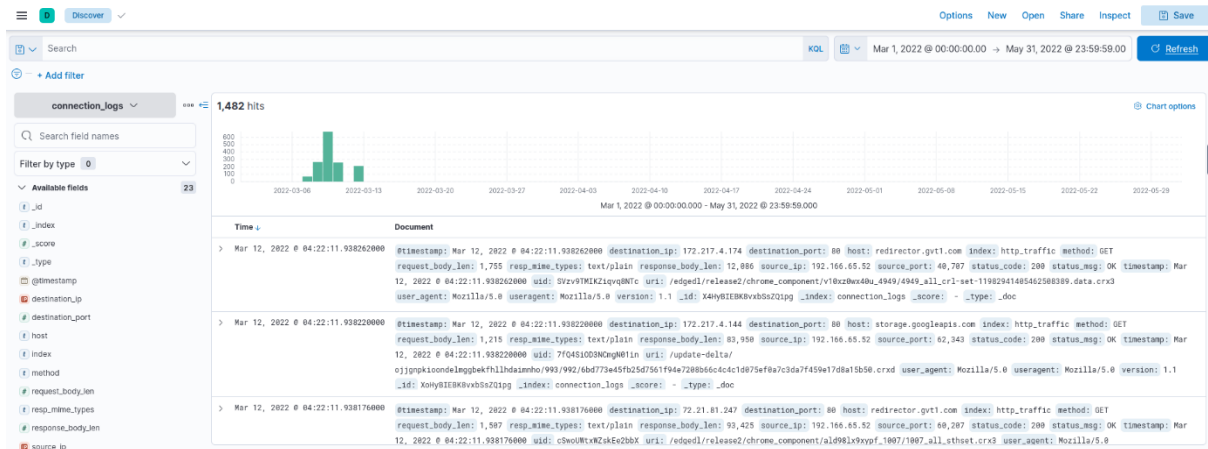
We, as a SOC monitoring agent named John, noticed suspicious alerts popping up from a user Browne from the HR department. Our task is to investigate what exactly was happening during the suspicious connection on the machine.



We must go through the connection logs to better understand the situation.

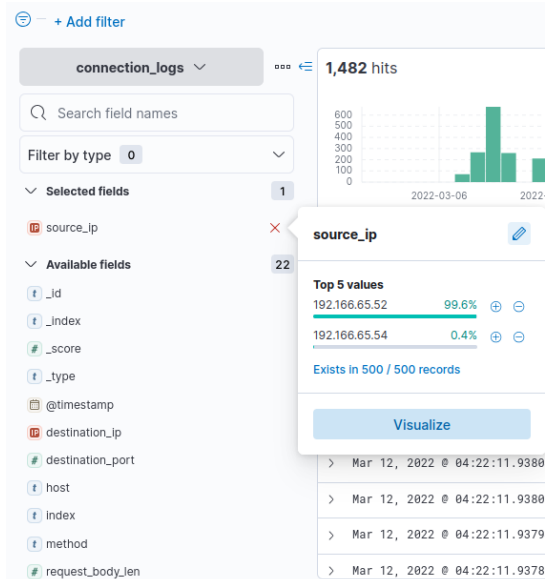
Step-by-step

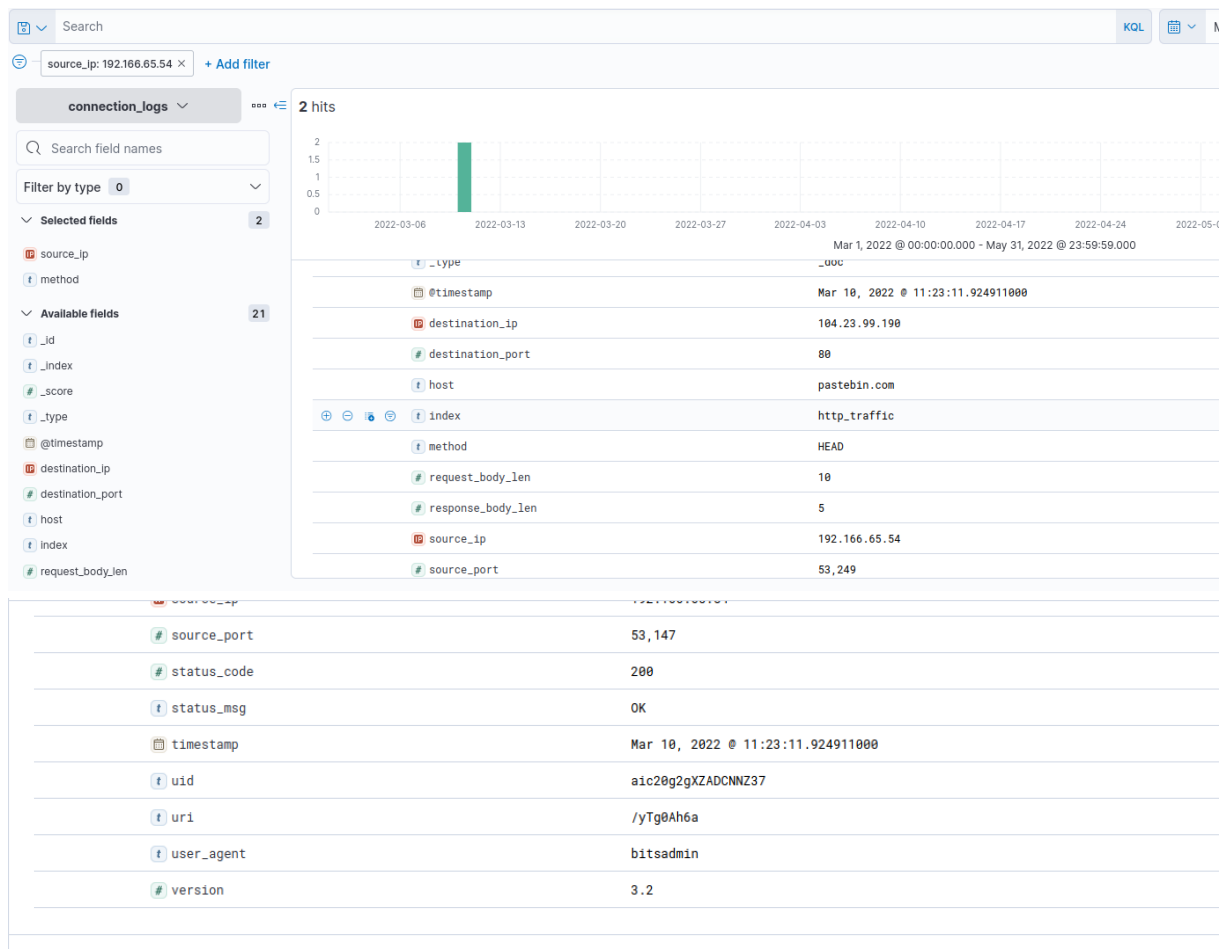
At first we had to change the timestamp to cover only March 2022. (the time alerts started popping up).



The total number of event sis **1482**.

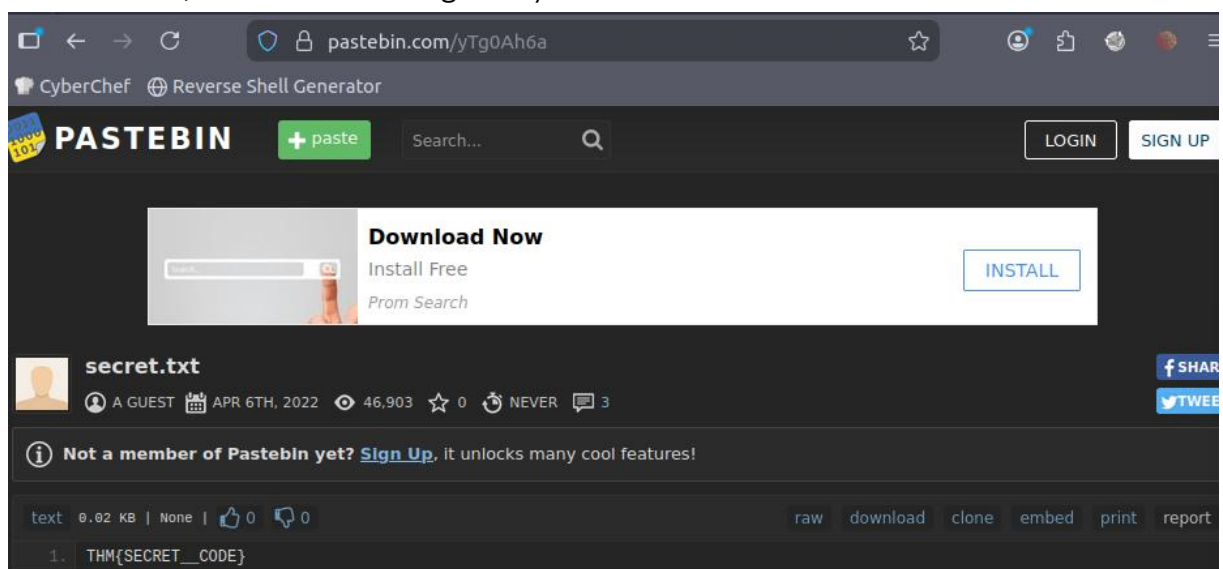
Then we traced the suspected IP address. We have found out two IP addresses, but only one made suspicious connection to file sharing website called **pastebin.com** by using legitimate Windows binary called **bitsadmin**.





The full URL of the C2 connection is : **pastebin.com/yTg0Ah6a**

We have also found out that file was accessed on this website (by typing the full URL into our search engine) (PAY ATTENTION: This challenge is done in sandbox environment therefore it's relatively safe to open potentially malicious websites in the safe environment, otherwise it's dangerous).



The name of the file is: secret.txt and contains code THM{SECRET_CODE}.

CONCLUSION

We can just estimate at this point, because of the limited resources we have, but it's highly possible the user's machine got compromised by malware from phishing email, specifically trojan horse, which hid his malicious intentions into legitimately looking application. Then this software installed another application that would help establish the connection to C2 server and thanks to it help control the user's machine to exploit it and steal information by pasting them into filesharing website (pastebin.com).

SOLUTION

At first we should isolate the device from the rest of the network. Then we should correlate the whole incident (where it started, who did it, why etc...). Hopefully everything is saved for better correlation in Sguil. Afterwards we block the attackers IP address (104.23.99.190) and domain name (pastebin.com) – which is often connected to frequent attacks such as malware payload hosting, command-and-control instructions, scripts, stolen credentials etc... We should also reset user passwords and reset configuration of the whole computer (check for possible persistence algorithms – such as when we reset our device the autorun malware still starts the C2 communication). We should also set IPS rule that should immediately block traffic when working with filesharing websites. Hopefully the malicious activity was only playful one and no severe harm had been caused.